

Arkime para análisis de tráfico de malware



Arkime

Pedro Egea Ortega

Índice

Análisis Spear Phishing (Dridex)..... 1

Identificando tráfico C2C (Emotet)..... 3

Identificando tráfico C2C (Lokibot)..... 6

Identificación de malware usando comunicaciones seguras con TLS y utilización de hashes

JA3 para detectar nodos del command&control..... 8

Análisis Spear Phishing (Dridex)

fichero: 01-04.spearphising-dridex.pcap

port.dst == 80 && http.uri != www.download.windowsupdate.com/*



Arkime Sesiones Vista SPI Gráfico SPI Conexiones Archivos Estadísticas Historial Configuración Usuarios v6.0.0

port.dst == 80 && http.uri != www.download.windowsupdate.com/

Todos (con precaución) Inicio 01/01/1970, 01:00 Fin 12/03/2026, 10:32:28 Límites Último Paquete Intervalo Auto

50 por página 1 Mostrando 1 - 3 de 3 entradas

Este cluster está configurado para ocultar el gráfico si se solicita un rango de tiempo de 30 días o más. Haz clic en el botón 'Obtener Datos de Visualización' de arriba para obtener datos de visualización para esta consulta (o abre el desplegable para más opciones).

	Start Time	Stop Time	Src IP / Country	Src Port	Dst IP / Country	Dst Port	Packets	Databytes / Bytes	Arkime Node	Info
tcp	2020/11/24 11:32:30	2020/11/24 11:32:31	192.168.56.103	49194	72.21.91.29	80	8	1,148 2,415	Arkime-virtual	Protocols • http tcp HTTP URI • ocsp.digicert.com/MFEwTzBNMEswSTAIBgUjDgMCGgUABBSAUOYBMq2awn1Rh6Doh%2FsBYgFV7gQUA95QN VbRTlms8KP/GvDI7190VUCEAH9e%2BlynXIEQLokvPvJE%3D
tcp	2020/11/24 11:29:44	2020/11/24 11:30:45	192.168.56.103	49183	23.40.121.183	80	9	2,098 2,608	Arkime-virtual	Protocols • http tcp HTTP URI • www.microsoft.com/bkliberts/MicBocCerAut_2010.06.23.ct
tcp	2020/11/24 11:29:27	2020/11/24 11:29:29	192.168.56.103	49176	185.81.96.5	80	564	604,965 636,023	Arkime-virtual	Protocols • http tcp HTTP URI • rasadbar.ir/hyswb.pdf

La sesión sospechosa es la 3ª

- 604,965 bytes → es la más grande con diferencia
- El host es rasadbar.ir → dominio iraní sin relación con Microsoft



HTTP

Method	GET (1)
Status code	200
Hosts	rasadbar.ir
Request Headers	connection host
Client Versions	1.1
Response Headers	accept-ranges connection content-length content-type date last-modified server
Server Versions	1.1
content-type Header	application/pdf
server Header	LiteSpeed
Body MD5s	770df303f86ac191c177035c214589ee
libfile content type	application/x-dosexec

La cabecera dice que el archivo es un pdf pero en el campo libfile content type podemos apreciar que se trata de un ejecutable Windows.

Buscamos en VirusTotal el hash MD5 770df303f86ac191c177035c214589ee y vemos que el archivo t6yswb.pdf se trata de un troyano

60/69 security vendors flagged this file as malicious

Reanalyze Similar More

ffcd3f21e103ef18413700ee91a9737900ea88fcae1607cffb4d7f587039504

Size: 590.50 KB | Last Analysis Date: 1 year ago

t6yswb.pdf

edit spreader

Community Score: 60 / 69 (-12)

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 9

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan.cridex/dridex

Threat categories: trojan downloader banker

Family labels: cridex dridex mint

Security vendors' analysis

Vendor	Detection
AhnLab-V3	Malware/Win32.RL_Generic.R356678
Alibaba	TrojanDownloader:Win32/Dridex.573077...
AliCloud	Trojan(downloader):Win/Cridex.pcf
ALYac	Trojan.Mint.Zamg.O
Antiy-AVL	GrayWare/Win32.Kryptik.ehls
Arcabit	Trojan.Mint.Zamg.O
Arctic Wolf	Unsafe
Avast	Win32:BankerX-gen [Trj]
AVG	Win32:BankerX-gen [Trj]
Avira (no cloud)	TR/AD.Dridex.yfpzu
BitDefender	Trojan.Mint.Zamg.O
Bkav Pro	W32.AIDetectMalware

Do you want to automate checks?

Identificando tráfico C2C (Emotet)

fichero: 02.c2-emotet.pcap

Ordenamos por tamaño y comprobamos uno muy grande. ¿Qué destino tiene?

Destino: 107.161.177.229:80

¿Qué aparece en el detalle que ya hemos visto?

Es la misma técnica que en Dridex — el archivo aparenta ser otra cosa (en este caso application/octet-stream) pero el análisis real del archivo revela que es un ejecutable Windows (.exe).

The screenshot shows the Arkime interface with a search bar at the top. Below the search bar, there's a table of captured packets. The first packet is highlighted with a red box. It's a TCP packet from 192.168.100.127 to 107.161.177.229 on port 80. The details pane on the right shows the HTTP request headers and body. The body content type is application/x-dosexec, which is highlighted with a red box.

Start Time	Stop Time	Src IP / Country	Src Port	Dst IP / Country	Dst Port	Packets	Databytes / Bytes	Arkime Node	Info
2020/11/28 15:13:57	2020/11/28 15:13:58	192.168.100.127	49220	107.161.177.229	80	327	242,550 / 260,424	Arkime-virtual	

General

Time: 2020/11/28 15:13:57 - 2020/11/28 15:13:58

Id: 201128-ZQVGPuJe45PipHyBvickHvn

Community Id: 1ERg37hFFlv+8Ch+s07B2mwuAA=

Node: Arkime-virtual

Protocol: http

Ethernet: 2048

IP Protocol: tcp

Src: Packets 115 Bytes 6,496 Databytes 82

Dst: Packets 212 Bytes 253,928 Databytes 242,468

Src Ethernet: Mac 12:a9:86:6c:77:de

Dst Ethernet: Mac 52:54:00:36:3e:ff

Src IP Port: 192.168.100.127 : 49220 (ARIN)

Dst IP Port: 107.161.177.229 : 80 (ARIN)

Payloads: Src 47454202636769 (GET /cgi) Dst 4854545029312e31 (HTTP/1.1)

Tags: out-of-order-dst

Files: /opt/arkime/raw/02.c2-emotet.pcap

TCP Flags: SYN 1 SYN-ACK 1 ACK 286 PSH 38 RST 1 FIN 0 URG 0

HTTP

Method: GET (1)

Status code: 200

Hosts: intrasistemas.com

Request Headers: connection host

Client Versions: 1.1

Response Headers: cache-control connection content-disposition content-transfer-encoding content-type date expires keep-alive last-modified pragma server set-cookie transfer-encoding x-powered-by

Server Versions: 1.1

Server Header: application/octet-stream

Body MD5: d925b3d4ab198a8edfca95dab2b20861

libfile content-type: application/x-dosexec

Queremos ver el tráfico post infección, filtramos entre el inicio de este paquete y 5 minutos más. En la tercera sesión vemos el request de nuestro troyano. Vemos dos sesiones subsiguientes y ese es el tráfico postinfección ¿Qué destino tienen estas dos sesiones?

Las dos sesiones post-infección tienen como destino 74.219.172.26:80 y 134.209.36.254:8080

The screenshot shows the Arkime interface with a search bar at the top. Below the search bar, there's a table of captured packets. The first packet is highlighted with a red box. It's a TCP packet from 192.168.100.127 to 107.161.177.229 on port 80. The details pane on the right shows the HTTP request headers and body. The body content type is application/x-dosexec, which is highlighted with a red box.

Start Time	Stop Time	Src IP / Country	Src Port	Dst IP / Country	Dst Port	Packets	Databytes / Bytes	Arkime Node	Info
2020/11/28 15:13:57	2020/11/28 15:13:58	192.168.100.127	49220	107.161.177.229	80	327	242,550 / 260,424	Arkime-virtual	

General

Time: 2020/11/28 15:13:57 - 2020/11/28 15:13:58

Id: 201128-ZQVGPuJe45PipHyBvickHvn

Community Id: 1ERg37hFFlv+8Ch+s07B2mwuAA=

Node: Arkime-virtual

Protocol: http

Ethernet: 2048

IP Protocol: tcp

Src: Packets 115 Bytes 6,496 Databytes 82

Dst: Packets 212 Bytes 253,928 Databytes 242,468

Src Ethernet: Mac 12:a9:86:6c:77:de

Dst Ethernet: Mac 52:54:00:36:3e:ff

Src IP Port: 192.168.100.127 : 49220 (ARIN)

Dst IP Port: 107.161.177.229 : 80 (ARIN)

Payloads: Src 47454202636769 (GET /cgi) Dst 4854545029312e31 (HTTP/1.1)

Tags: out-of-order-dst

Files: /opt/arkime/raw/02.c2-emotet.pcap

TCP Flags: SYN 1 SYN-ACK 1 ACK 286 PSH 38 RST 1 FIN 0 URG 0

HTTP

Method: GET (1)

Status code: 200

Hosts: intrasistemas.com

Request Headers: connection host

Client Versions: 1.1

Response Headers: cache-control connection content-disposition content-transfer-encoding content-type date expires keep-alive last-modified pragma server set-cookie transfer-encoding x-powered-by

Server Versions: 1.1

Server Header: application/octet-stream

Body MD5: d925b3d4ab198a8edfca95dab2b20861

libfile content-type: application/x-dosexec

- Hay un número pequeño de datos simplemente mirando el tamaño
- Cada carácter representa un byte por lo que hay pocos bytes
- Poca información enviándose al panel C2
- No podemos interpretar estos bytes porque están cifrados. Porqué:
 - Emotet usa cifrado para proteger estos datos
 - Aunque no se esté usando TLS, se establece una comunicación segura para cifrar los datos que envía
- Como conclusión sabemos que, pese a la infección, se está enviando relativamente poca información de la víctima al C2

	2020/11/28 15:13:57	2020/11/28 15:13:58	192.168.100.127	49220	107.161.177.229	80	327	242,550 260,424	Arkime-virtual
tcp	2020/11/28 15:14:07	2020/11/28 15:14:37	192.168.100.127	49365	74.219.172.26	80	14	5,160 5,940	Arkime-virtual

Descargar PCAP
 Origen (raw)
 Destino (raw)
 % Enlace
 Columnas ▾
 Acciones ▾

General

Time 2020/11/28 15:14:07 - 2020/11/28 15:14:37

ID 201128-ZlQjCmjdLYbz1t8SPel

Community M: 19LFMFeZzOHLETYmmM8/5opA-

Note: Arkime-virtual

Protocols: http tcp

EtherType: 2048

IP Protocol: tcp

Sec: Packets 8 Bytes 5,604 Databytes 5,160

Dst: Packets 6 Bytes 336 Databytes 0

Src Ethernet: Mac 12:a9:86:c7:7d:e

Dst Ethernet: Mac 52:54:00:36:3e:f7

Src IP Port: 192.168.100.127 : 49365 (ARIN)

Dst IP Port: 74.219.172.26 : 80 (ARIN)

HTTP

Method: POST (1)

Hosts: 74.219.172.26

User Agents: Mozilla/5.0 (Windows NT 6.3; Win64; x64; rv:75.0) Gecko/20100101 Firefox/75.0

Request Headers: accept accept-encoding accept-language cache-control connection content-length content-type dnt host referer upgrade-insecure-requests user-agent

Clients Versions: 1.1

Content type Header: multipart/form-data; boundary=-----XIMEIOEAAhtgCq9D7GSDP

Referer Header: 74.219.172.26/1NUtSzS9/Rhzyx4LMicdxaxOKRrIsBEPJnsGuJsYmWXXoXrKcYMMCo4OXFw6smhsJMdX7mPi

Body MD5s: 2ae2dc4c72444b64f7e958c51cc82163

libfile content type: text/plain

[illegible]

Analizando la comunicación con el C2, lo primero que llama la atención es que las cabeceras HTTP imitan perfectamente las de un navegador real. Tiene User-Agent de Firefox, Accept-Language, DNT, e incluso el Referer, que es importante porque su ausencia habría disparado alertas en algunos IDS.

Si bajamos al cuerpo de la petición, vemos una serie de caracteres sin sentido que corresponden a los datos cifrados que el troyano envía al panel C2. Aunque no se está usando TLS, Emotet cifra los datos por su cuenta, por lo que no podemos interpretarlos. El Content-Length es de 4500 bytes, una cantidad bastante pequeña, lo que nos dice que en este momento se está enviando poca información de la víctima al C2.

Identificando tráfico C2C (Lokibot)

fichero: 03.c2-lokibot.pcap

Al cargar todos los datos de la sección HTTP, lo primero que llama la atención es el campo User Agent, que muestra el valor Mozilla/4.08 (Charon; Inferno). Este es el user agent distintivo que Lokibot ha usado históricamente en sus comunicaciones, y es un indicador muy claro de infección ya que ningún navegador legítimo utiliza ese identificador.

HTTP Status Code	404 (4) 200 (1)
HTTP Status Code Cnt	1 (5)
HTTP URI	bibpap.com/amb/pin.php (4) posqit.net/vcv/120131078.exe (1)
HTTP URI Cnt	1 (5)
HTTP URI Path	/amb/pin.php (4) /vcv/120131078.exe (1)
HTTP URI Path Cnt	1 (5)
HTTP User	No hay datos para este campo
HTTP User Cnt	No hay datos para este campo
HTTP Useragent	Mozilla/4.08 (Charon; Inferno) (4)
HTTP Useragent Cnt	1 (4)
HTTP XFF ASN	No hay datos para este campo

Pivotando sobre ese user agent, podemos identificar la URL del panel de control, que en este caso es bibpap.com/amb/pin.php. Esta URL aparece repetida varias veces en el campo HTTP URI, lo que corresponde a los sucesivos check-ins del malware con su panel C2.

En la sección DNS de la Vista SPI se pueden ver las resoluciones de nombres realizadas por la máquina infectada, donde aparecen bibpap.com y posqit.net entre los hosts consultados. Esto confirma que el equipo comprometido estaba resolviendo activamente los dominios del C2.

Algo destacable de esta infraestructura es que el panel devuelve un código HTTP 404 Not Found con un body que incluye File not found, configurado deliberadamente para confundir al analista y hacerle creer que el malware no ha podido contactar con su panel. Sin embargo, el user agent distintivo y la repetición de las peticiones dejan claro que la comunicación sí se ha establecido con éxito.

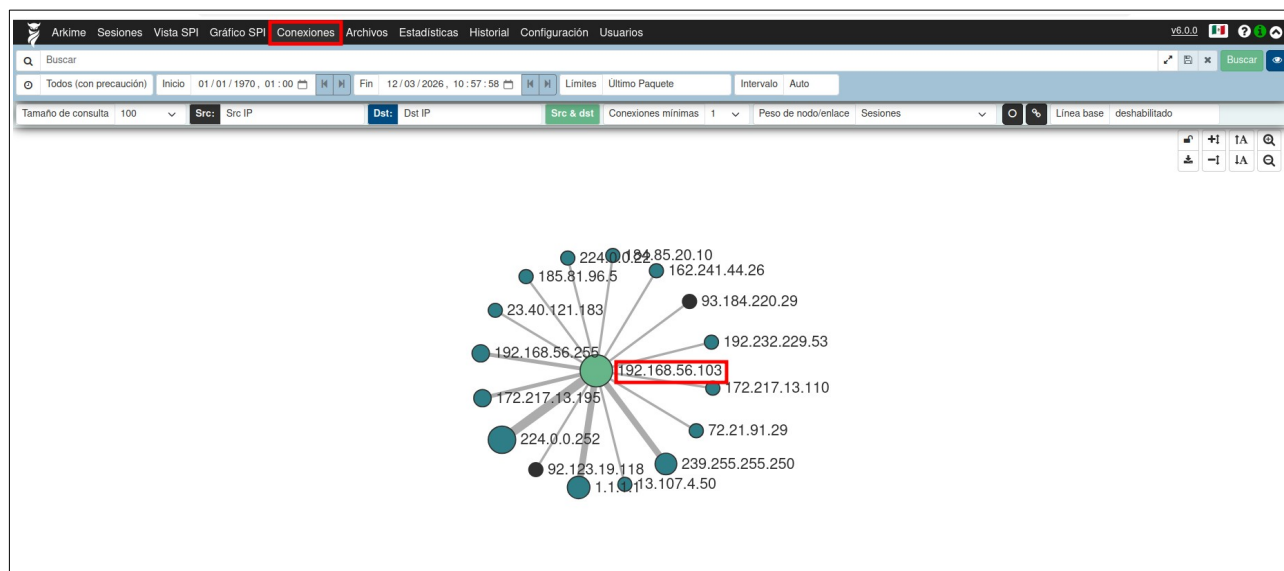
Los datos enviados al panel aparecen cifrados, por lo que no es posible interpretarlos directamente. El siguiente paso sería buscar publicaciones o scripts públicos que permitan descifrar el tráfico de Lokibot, aunque esto no siempre está disponible. En ese caso, solo queda concluir que el malware realiza check-ins periódicos con su C2 enviando información de la víctima de forma cifrada.

DNS Answer IP	51.137.137.111 ⁽⁴⁾ 51.145.123.29 ⁽⁴⁾ 89.208.210.239 ⁽²⁾ 131.107.255.255 ⁽²⁾ 107.189.7.179 ⁽¹⁾
DNS Answer MX	No hay datos para este campo
DNS Answer NS	No hay datos para este campo
DNS Answer NSEC	No hay datos para este campo
DNS Answer Priority	No hay datos para este campo
DNS Answer RRSIG	No hay datos para este campo
DNS Answer TTL	3,600 ⁽⁷⁾ 300 ⁽⁶⁾
DNS Answer TXT	No hay datos para este campo
DNS Answer Type	A ⁽⁹⁾
DNS Answers Cnt	3 ⁽³⁾ 1 ⁽²⁾ 2 ⁽²⁾ 4 ⁽²⁾ 0 ⁽¹⁾
DNS Header Flags	RA ⁽¹⁰⁾ RD ⁽¹⁰⁾
DNS Header Flags Cnt	No hay datos para este campo
DNS Host	time.windows.com ⁽⁴⁾ dns.msftncsi.com ⁽³⁾ isatap ⁽³⁾ bibpap.com ⁽²⁾ hr1-pc ⁽²⁾ wpad ⁽²⁾ posqit.net ⁽¹⁾
DNS Host Cnt	1 ⁽¹⁷⁾
DNS IP	51.137.137.111 ⁽⁴⁾ 51.145.123.29 ⁽⁴⁾ 89.208.210.239 ⁽²⁾ 131.107.255.255 ⁽²⁾ 107.189.7.179 ⁽¹⁾

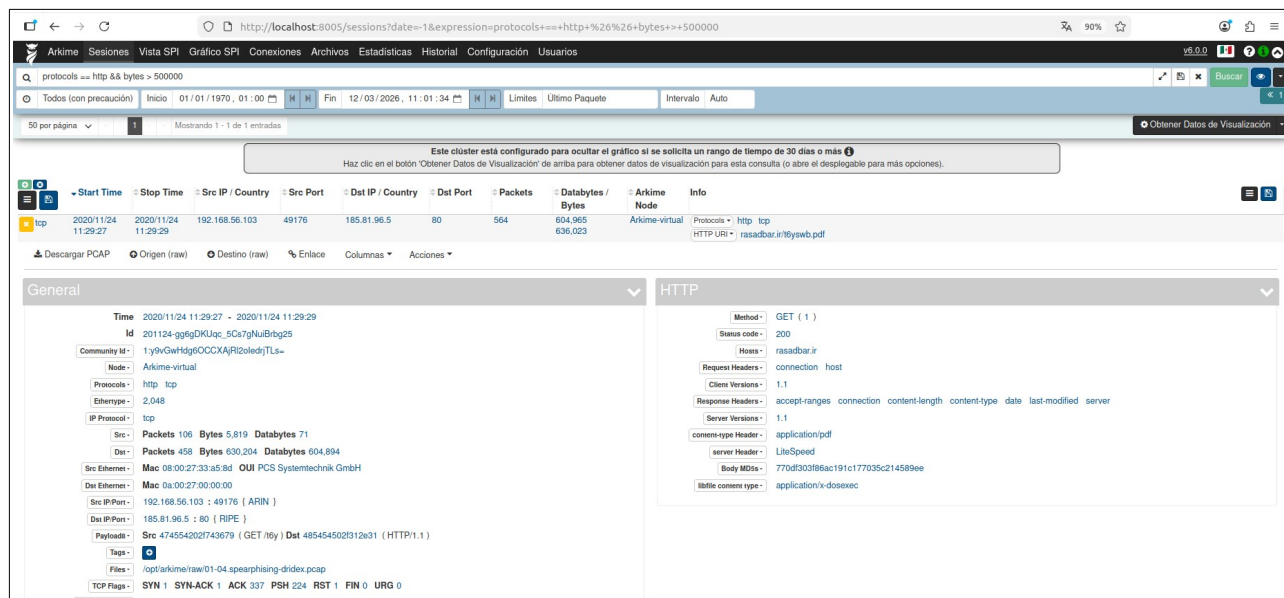
Identificación de malware usando comunicaciones seguras con TLS y utilización de hashes JA3 para detectar nodos del command&control

fichero: 01-04.spearphising-dridex.pcap

El nodo central y más grande, con todas las conexiones saliendo de él, es claramente 192.168.56.103. Esta es la máquina víctima infectada con Dridex.

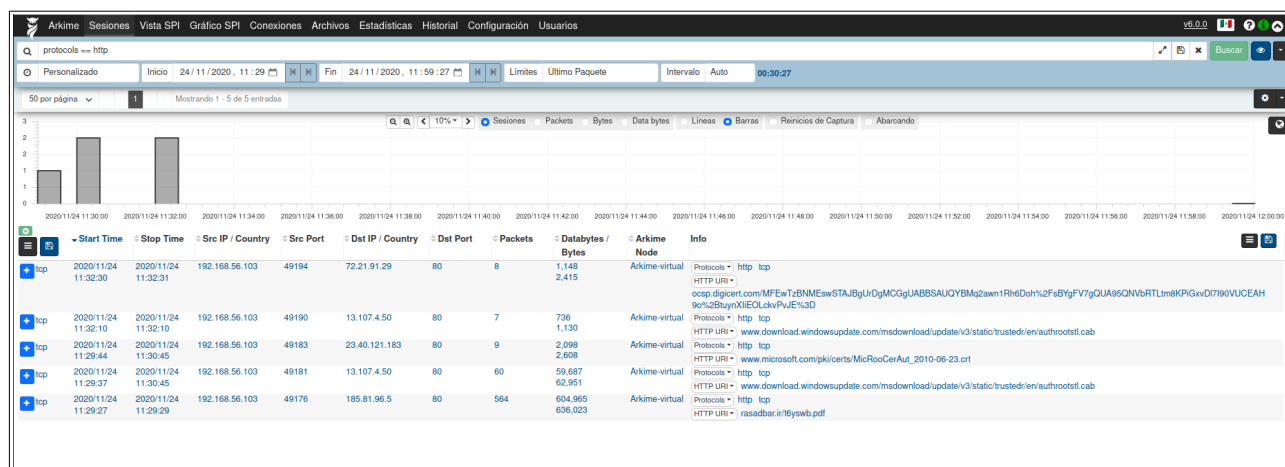


protocols == http && bytes > 500000



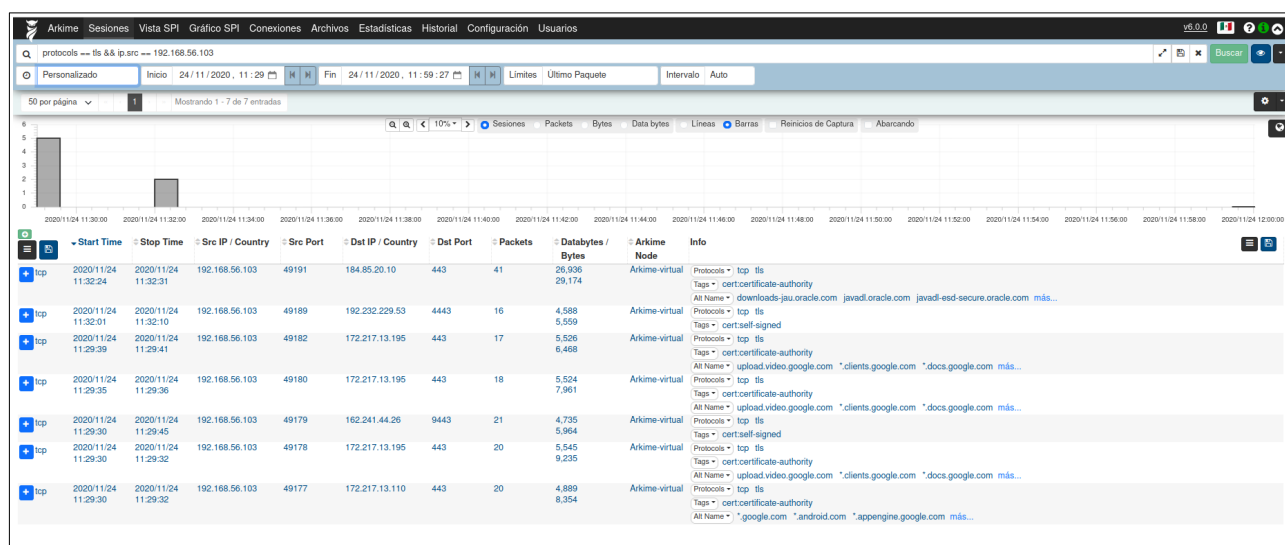
El troyano Dridex está enmascarado como un archivo PDF (rasadbar.ir/t6yswb.pdf, content-type: application/pdf), pero en realidad es un ejecutable Windows (libfile content type: application/x-dosexec). Esta técnica engaña tanto al usuario como a sistemas de seguridad básicos que confían en el Content-Type declarado.

Quitamos el filtro de los bytes y seleccionamos el tiempo desde esta sesión y media hora más. Vemos tráfico legítimo como windows update u otros.



Cambiamos el filtro y quitamos el número de bytes y ponemos para ver si el malware usa cifrado, manteniendo la IP de nuestro host investigado.

`protocols == tls && ip.src == 192.168.56.103`



Parece que hay sesiones legítimas pero también hay un tráfico TLS por el puerto no estándar. ¿Qué puertos son?

Puertos no estándar: 4443 y 9443 (TLS fuera del puerto 443 habitual)

Miramos la información del certificado de estas sesiones y parece autofirmado y "raro".
También tenemos valores de hashes JA3 y JA3s

protocolo == tls && ip.src == 192.168.56.103

Personalizado Inicio 24/11/2020, 11:29 Fin 24/11/2020, 11:59:27 Límites Último Paquete Intervalo Auto

50 por página Mostrando 1 - 7 de 7 entradas

Protocolo	Time	Id	Community Id	Node	Protocols	Ethernet	IP Protocol	Src	Dst	Src Ethernet	Dst Ethernet	Src IP Port	Dst IP Port	Payload	Tags	Files	TCP Flags	TCP Initial Seq	IP TTL
tcp	2020/11/24 11:32:24	2020/11/24 11:32:31	192.168.56.103	49191	184.85.20.10	443	41	26.936	29.174	Arkime-virtual	Protocolo: tcp, tls	Tags: cert, certificate-authority	Alt Name: downloads-jau.oracle.com javadi.oracle.com javadi-esd-secure.oracle.com más...						
tcp	2020/11/24 11:32:01	2020/11/24 11:32:10	192.168.56.103	49189	192.232.229.53	4443	16	4.588	5.559	Arkime-virtual	Protocolo: tcp, tls	Tags: cert, self-signed							

Descargar PCAP Origen (raw) Destino (raw) Enlace Columnas Acciones

General

Time: 2020/11/24 11:32:01 - 2020/11/24 11:32:10

Id: 201124-gg4Jwld93yxOULT9UUhgoZGX

Community Id: 1-VWp38VFBwBadyIqYxXNZ2HDe0

Node: Arkime-virtual

Protocols: tcp, tls

Ethernet: 2,048

IP Protocol: tcp

Src: Packets: 8 Bytes: 3,916 Databytes: 3,448

Dst: Packets: 8 Bytes: 1,643 Databytes: 1,140

Src Ethernet: Mac: 08:00:27:33:a5:8d OUI: PCS Systemtechnik GmbH

Dst Ethernet: Mac: 08:00:27:00:00:00

Src IP Port: 192.168.56.103 : 49189 (ARIN)

Dst IP Port: 192.232.229.53 : 4443 (ARIN)

Payload: Src: 1603010063010000 (c) Dst: 1603010051020000 (Q)

Tags: cert, self-signed

Files: /opt/arkime/raw/01-04_spearphising-dindex.pcap

TCP Flags: SYN 2 SYN-ACK 1 ACK 6 PSH 7 RST 0 FIN 0 URG 0

TCP Initial Seq: Src: 2,783,304,935 Dst: 0

IP TTL: Src: 128 Dst: 64

TLS

Version: TLSv1

Cipher: TLS_RSA_WITH_AES_128_CBC_SHA

JA3: 67762b0ff63aad00d3b0e4b1acd8b5

JA3s: 4192c0a946c5b9b544b4656d9f624a4

JA4: 110120400_d94a65cd899_c35b4a14be45

Certificate: Serial: 00e9262a75bc121cb7 [07:df:e2:02:3b:c2:db:47:62:27:71:f1:0f:1b:54:41:07:6c:3c:4a]

Not Before: 2020/11/16 09:06:05 Not After: 2021/05/17 10:06:05 Days Valid For: 182 Seconds Valid For: 15,724,800 Days Remain

Issuer: Common trinioup.3motbhadwimotorcycles Issuer Org Ppsolrope A.E. Subject: Common trinioup.3motbhadwimotorcycles Subject Org Ppsolrope A.E. Public Algorithm: rsaEncryption